

Career Compass — Security & Compliance Audit

Scope: Application security (RLS, XSS, secrets, authn/authz, share-token math, dependency CVEs, secret leakage in git history) + India-specific compliance (DPDPA 2023, IT Rules 2021, minors' data, parental consent, grievance officer).

Standard: OWASP ASVS 4.0 Level 1 + DPDPA 2023 (Digital Personal Data Protection Act, enforced 2025) + IT Rules 2021 + Supabase Security Best Practices.

Findings Summary

Severity	Count	Examples
● P0 — Critical	6	Anthropic API key in browser bundle, real user PII committed to git, no privacy policy, no parental consent, counsellor authorisation broken, debug logs leak PII
● P1 — High	7	Share-token policy too permissive, no rate limiting, no audit log, weak session management, no DPIA, missing data-retention policy, no grievance officer
● P2 — Medium	6	Dependency hygiene, no CSP, no SRI, missing security headers, weak password policy, no MFA
● Informational	4	Disclosure hardening, OAuth scopes, etc.

Overall Posture: ⚠️ **Not ready for production.** The app processes PII of minors (13–17) without a single one of DPDPA's required controls. A pilot launch in current state exposes the founder to enforcement action (fines up to ₹250 Cr) and civil liability.

Section A — Application Security

A.1 ● **P0 — Anthropic API Key in the Browser Bundle**

Location: `src/pages/Results.tsx:216`

```
const apiKey = import.meta.env.VITE_ANTHROPIC_API_KEY
...
fetch('https://api.anthropic.com/v1/messages', {
  headers: {
    'x-api-key': apiKey,
    'anthropic-dangerous-direct-browser-access': 'true',
  },
  ...
})
```

Why this is a P0: Vite bundles every `VITE_`-prefixed env var into the *client* JS bundle. The Anthropic team explicitly named the header `dangerous-direct-browser-access` to flag exactly this anti-pattern. Any visitor opens DevTools → Network → sees the key. They can then:

- Run unlimited spend on your Anthropic account (financial DoS).
- Use the key to call models for unrelated purposes attributable to your org.
- Embed the key in malicious sites that show "free Claude" to phish.

Verification: Run `npm run build && grep -r "VITE_ANTHROPIC" dist/` — the literal env-var name (and at runtime, the key value) will appear in the output bundle.

Fix:

1. Move the call to a **Supabase Edge Function** (`supabase/functions/ai-narrative/index.ts`).
2. Store the key as a Supabase function secret: `supabase secrets set ANTHROPIC_API_KEY=sk-ant-...`
3. From the client, call the Edge Function URL with the user's Supabase JWT — auth-gates the endpoint to logged-in students only.
4. **Rotate the existing key immediately** (assume it is already compromised).

A.2 ● P0 — Real User PII Hard-Coded in `migrations/006_fix_counsellor_profile.sql`

Location: `supabase/migrations/006_fix_counsellor_profile.sql:22, 28, 42, 46`

```
WHERE u.email = 'vasanthk@gmail.com'
...
'Vasanth K',
...
'DPS Vasanj Kunj', -- note: also misspelled (should be Vasant Kunj)
'Delhi',
```

Why this is a P0:

- A real person's **name + email + school + city** is now in the public git history of this repository forever.
- This is a **DPDPA Section 4 violation** (no lawful basis for processing) and a **Section 6 violation** (consent must be informed and specific — no one consents to having their email written into a SQL file).
- It is a **Section 8(7) violation** specifically for minors if Vasanth K is a school counsellor for under-18s (the Act extends to anyone whose data touches a minor's processing context).
- Git history rewriting alone is not sufficient under DPDPA — the person has the **right to be notified of the breach** (Section 8(6)).

Fix (in order):

1. **Contact Vasanth K** by email; notify and apologise.
2. **Rewrite git history** to scrub: `git filter-repo --replace-text expressions.txt` on a fresh clone, force-push, and ask collaborators to re-clone.
3. **Re-create the migration** as a parameter-driven script that reads the email at deploy time, never committing it.
4. **Add a pre-commit hook** (e.g. `git-secrets` or `gitleaks`) that blocks any file containing `@gmail.com`, `@yahoo.com`, or `@<your-school-domains>` from being committed.
5. **Audit every other migration** for similar leakage — the migration history shows 9 files, each should be reviewed.

A.3 ● P0 — Counsellor Authorisation is Broken

Location: `supabase/migrations/008_drop_counsellor_policies.sql`

Migration 008 **drops** the two RLS policies that let counsellors see student profiles and results, citing infinite-recursion bugs. The migration's comment says *"Phase D has been removed from the app; these are no longer needed."* — but:

- `src/pages/CounsellorDashboard.tsx` (499 LOC) still exists.
- `src/App.tsx` still routes `/counsellor/dashboard` → `<CounsellorDashboard />`.
- Commit `973b6c8` is titled *"feat: remove Phase D counsellor dashboard from user journey"* but commit `fac0bf0` ("feat: admin role, mobile fixes, **dashboard improvements**") suggests the dashboard is still alive.

So one of two states is true today, and **both are bugs**:

State A — Counsellors can log in, but the dashboard is blank (RLS rejects every query). User-visible: empty dashboard with no error.

State B — Counsellors gained broader access via some other code path (e.g. RLS isn't actually enforced because the JS client is using the service-role key, or admin policy is misconfigured, or counsellors are using share tokens). Worse than blank — they may be reading data they shouldn't.

Action required:

1. Decide whether the counsellor feature is in or out.
2. If **in**: re-implement counsellor RLS using the `SECURITY DEFINER` pattern used in migration 009 (`is_admin()`).
Pattern:

```
create or replace function public.is_counsellor_for(p_student_id uuid)
returns boolean language sql security definer stable as $$
  select exists (
    select 1
    from public.profiles c
    join public.profiles s on s.school_name = c.school_name
    where c.id = auth.uid() and c.role = 'counsellor' and s.id = p_student_id
  );
$$;

create policy "Counsellors read same-school students"
on public.profiles for select
using (public.is_counsellor_for(id));
```

3. If **out**: delete `CounsellorDashboard.tsx`, remove the `/counsellor/*` routes, and remove `'counsellor'` from the `profiles.role` CHECK constraint.

A.4 ● P0 — Debug `console.log` Statements Leak User Answers to the Browser Console

Location:

- `src/pages/Results.tsx:366–387` (9 statements)
- `src/components/assessment/AssessmentEngine.tsx:148, 171, 234, 256` (4 statements)

The Results page logs:

```
console.log('aptMap:', aptMap) // entire answer map for aptitude
console.log('intMap:', intMap) // entire answer map for interest
console.log('perMap:', perMap) // entire answer map for personality
```

Plus the assessment ID and the calculated scores.

Why this is a P0 under DPDPA:

- A minor's psychometric responses are **sensitive personal data** under DPDPA Section 9 (interpretive — the Act recognises a child's data as warranting additional protection).
- Anything in `console.log` is accessible to:
 - Browser extensions (you've granted *some* of these to every visitor without knowing).
 - Any analytics SDK that scrapes console output (some session-replay tools do).
 - Anyone "shoulder surfing" or screen-sharing during a parent-student session.
- This is a **disclosure of personal data without consent**.

Fix: wrap or strip:

```
if (import.meta.env.DEV) console.log(...)
```

...or run a Vite build plugin to strip `console.*` in production (`vite-plugin-terser` 's `drop_console: true`).

A.5 ● P1 — Share-Token RLS Policy Is "Allow Anyone Who Knows the Token"

Location: `supabase/migrations/001_initial_schema.sql:135–137`

```
create policy "Anyone can view result by share token"
on public.results for select
using (share_token is not null);
```

Analysis: Every row with a non-null `share_token` is **readable to every anonymous visitor**. The protection relies entirely on the secrecy of the token — 16 bytes (128 bits) via `gen_random_bytes(16)`, encoded as hex. The token entropy is fine (2^{128} brute force is infeasible).

But:

1. **The policy permits SELECT on the whole row**, including `student_id` (which is a FK to a real user's UUID). An attacker who knows one token learns a real user UUID, which can be used elsewhere if any other endpoint leaks data keyed on UUID.
2. **No expiry on share tokens**. A token shared in 2026 still works in 2031. DPDPA principle of **storage limitation** (Section 8(7)) suggests these should expire — say, 90 days.
3. **No revocation**. Even if a parent-child relationship breaks down, the link is permanent.
4. **No view counter / audit**. You don't know if a link has been opened 1 time or 10,000 times.

Fix:

- Add `share_token_expires_at` `timestampz` and update the policy to `using (share_token is not null and share_token_expires_at > now())`.
- Add a `share_token_views` counter incremented via a Postgres function called from the shared page.
- Add a "revoke share link" button on the Results page.
- Consider returning only the *fields needed by the share view* via a Postgres view (`public.shared_result_v`) instead of letting the policy expose the full `results` row.

A.6 ● P1 — No Rate Limiting Anywhere

There is no rate limiting on:

- Login attempts (Supabase Auth has built-in throttling but it's lenient).
- Signup (a bot can create 10,000 accounts).
- The (currently insecure) Anthropic API call — once exposed, the key gets drained at AWS-scale.
- Share-token reads (a scraper can enumerate any leaked token space).

Fix: add Cloudflare/Netlify edge rate-limit rules at the network layer. For the AI Edge Function, use Supabase's `rls` + a `usage_counters` table keyed on `(user_id, day)`.

A.7 ● P1 — No Audit Log for Admin / Counsellor Reads

`AdminDashboard.tsx` (281 LOC) and the admin RLS (migration 009) let an admin read *every student's profile and result*. There is no `admin_audit_log` table recording which admin viewed which student when. This is a **DPDPA Section 8(4) accountability** failure — an org processing personal data must be able to demonstrate compliance.

Fix: create `admin_audit_log` with `(admin_id, action, target_student_id, target_resource, accessed_at)`; insert from a trigger or from a `pg_audit` extension on the relevant tables.

A.8 ● P2 — Missing Security Headers

The repository has a minimal `netlify.toml`:

```
[build]
  publish = "dist"
  command = "npm run build"

[[redirects]]
```

```
from = "/*"  
to = "/index.html"  
status = 200
```

No `[[headers]]` section. The deployed app therefore has none of:

- `Content-Security-Policy`
- `Strict-Transport-Security`
- `X-Content-Type-Options: nosniff`
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Permissions-Policy`

Fix: add a `[[headers]]` block to `netlify.toml`. A strict CSP is feasible because the app loads no third-party scripts; tighten to `default-src 'self'; connect-src 'self' https://*.supabase.co https://api.anthropic.com; img-src 'self' data;; style-src 'self' 'unsafe-inline'`.

A.9 🟡 P2 — Weak Password Policy

`src/pages/Signup.tsx` accepts any password Supabase accepts (default minimum: 6 chars). For a product targeting school students:

- Many students will reuse a 6-char password from another service.
- A successful credential-stuffing run leaks an entire school's psychometric profile.

Fix: Supabase Auth → enable "Strong password" (min 10 chars, mixed case + digit), enable HIBP password check.

A.10 🟡 P2 — No MFA Option for Counsellors/Admins

Counsellors and admins have access to many students' data. They should be able to enable TOTP MFA. Supabase Auth supports it but it's not enabled in the app.

A.11 Dependency Hygiene

`package.json` includes:

- `@anthropic-ai/sdk: ^0.78.0` — but the code calls `fetch()` directly. The SDK is bundled (~80KB gzipped) and unused. **Remove.**
- `react-router-dom: ^6.20.0`, `react: ^18.2.0`, `@supabase/supabase-js: ^2.38.4` — all current as of repo date but should run `npm audit` weekly.
- `jspdf: ^4.2.0` — historically had occasional XSS-in-PDF advisories; check.
- No automated dependency update bot (Dependabot / Renovate) is configured.

Fix:

- `npm uninstall @anthropic-ai/sdk` (after the SDK move to Edge Function, the *client* doesn't need it).
 - Enable GitHub Dependabot.
 - Add `npm audit --production` to CI (no CI is configured today — see Technical Audit).
-

A.12 ✅ What's Done Right

- **RLS is enabled** on every user-data table (`profiles`, `assessments`, `assessment_responses`, `results`, `parent_student_links`).
- **Auth-trigger pattern** (`handle_new_user`) is server-side and safe; uses `security definer set search_path = public`.
- **No `dangerouslySetInnerHTML`** in the codebase — no React XSS surface.
- **No `eval()`, no `Function()` constructor.**
- `.env` is in `.gitignore` (verified) and `git log -- .env` shows it has never been committed.
- **Share tokens use `gen_random_bytes(16)`** (cryptographic randomness) — good entropy choice.

- **Service-role key is not used in the client** (only the anon key is, via `client.ts`).

Section B — DPDPA 2023 Compliance

*The Digital Personal Data Protection Act, 2023, with Rules notified through 2024–2025, governs every Indian-resident user's data. **Career Compass processes data on minors (13–17)** which triggers the strictest tier of the Act.*

B.1 ● P0 — No Privacy Policy

The repository has no `privacy.html`, no `/privacy` route, no document anywhere stating what data is collected, why, and for how long. **DPDPA Section 5 requires a notice to the data principal at or before collection.** This is the single most basic compliance artefact and is missing.

Required notice contents (Section 5):

1. Description of the personal data being collected.
2. Specific purpose for processing.
3. Manner of withdrawal of consent.
4. Manner of exercising data-principal rights (Section 11–14).
5. Manner of filing a complaint with the Data Protection Board.

Fix: create `/privacy` page + a checkbox in signup that says *"I have read and agree to the Privacy Policy"* — and a parent equivalent. Use the template at <https://dpdpa.gov.in/> (when published) or a known counsel's template.

B.2 ● P0 — No Parental Consent Flow

DPDPA Section 9 is the critical one:

"The Data Fiduciary shall, before processing any personal data of a child... obtain verifiable consent of the parent of such child."

A "child" under the Act is anyone **under 18**. Career Compass's target market is **13–17**. So **every single user signup requires verifiable parental consent** — not the *parent* signing up themselves, but the parent *consenting on the child's behalf before the child's account is created or used*.

What "verifiable" means is being clarified in Rules, but the practical standard is:

- Parent provides their own email/phone.
- Parent receives a confirmation link or OTP.
- Parent affirmatively clicks/enters OTP.
- A timestamped record of consent is stored.

Current state: A 14-year-old can sign up directly on `/signup`, take all 3 assessments, and have a full report generated — with the parent only optionally invited later via a share link. This **inverts the legal requirement**.

Fix:

1. Restructure signup: student enters details → parent's email/phone is mandatory → parent receives an OTP/link → student account is *frozen* until parent confirms → only then can the student access the assessment.
2. Store parental consent record: `(student_id, parent_email, consent_method, consent_at, ip_address)`.
3. Allow parent to revoke consent at any time, which freezes the account and triggers Right-to-Erasure (B.4).
4. **Section 9(3) also bans behavioural tracking of minors and targeted ads** — confirm no analytics provider you add will profile users under 18. If you add Google Analytics, configure "consent mode" with denial for minors.

B.3 ● P0 — No "Tracking and Targeted Advertising" Prohibition Enforcement

DPDPA Section 9(3): Data fiduciaries are prohibited from tracking, behavioural monitoring, or targeted advertising directed at children. This is **absolute** (the central govt can exempt classes of fiduciaries but Career Compass would not qualify).

Even though Career Compass doesn't run ads today, the moment you add:

- Google Analytics with default settings → behavioural tracking.
- Meta Pixel for a parent-acquisition campaign → tracking minors via family-link inference.
- Hotjar/FullStory for session replay → behavioural monitoring.

...you breach Section 9(3). **Make a policy decision now**, document it in `docs/compliance/`, and choose analytics that allow non-tracking modes (PostHog without `$autocapture`, Plausible, Fathom).

B.4 ● P1 — No Right-to-Erasure / Right-to-Correction Flow

DPDPA Section 12-13 grants data principals the right to:

- Correct inaccurate or incomplete data.
- Erase their data ("right to be forgotten").
- Obtain a summary of data processed.

The app has `ProfileEdit.tsx` (168 LOC) which covers basic correction. There is **no "Delete my account" button anywhere**. Even Supabase Auth admin has to manually go drop rows.

Fix:

- Add "Delete my account" to `ProfileEdit`, hitting a Supabase Edge Function that:
 1. Cascades deletes via `on delete cascade` (already wired in schema).
 2. Deletes the `auth.users` row.
 3. Records the deletion in an `erasure_log` (for proof of compliance).
 - For minors, the **parent** must also be able to trigger erasure (Section 9(2)(a) — minor's rights are exercised through the parent).
-

B.5 ● P1 — No Data Protection Officer / Grievance Officer Designated

DPDPA Section 10(2)(b) requires every Data Fiduciary to:

- Publish the contact details of a person who can answer questions about processing.
- For **Significant Data Fiduciaries** (Section 10) — likely Career Compass if you cross volume thresholds — appoint a **Data Protection Officer** based in India.

Current state: the Footer (`src/components/layout/Footer.tsx`) lists no compliance contact.

Fix: add `/contact-grievance` page with an email (`grievance@careercompass.in`), a postal address, and response-time commitment (Rules require 7 days for initial acknowledgement, 30 days for resolution).

B.6 ● P1 — No Data Retention Policy

The schema has no `deleted_at`, no TTL, no archive process. Records stay forever. This violates **DPDPA Section 8(7)** (storage limitation):

"A Data Fiduciary shall not retain personal data... after the purpose for which it was collected is no longer being served."

A Class 10 student who completed the assessment in 2024 has no legitimate need for their data to live in your DB in 2034.

Fix: define a retention policy in `docs/data-retention.md` :

- Active accounts: retain indefinitely.
- Inactive accounts (no login for 24 months): auto-anonymise PII (clear `email`, `full_name`, `phone`, keep `result.science_score` for aggregate stats).
- Completed assessments: keep responses for 3 years post-completion, then delete.
- Soft-deleted accounts: hard-delete after 30-day grace period.

Implement via a daily Supabase scheduled function.

B.7 ● P1 — No Data Protection Impact Assessment (DPIA)

A DPIA is required for "high-risk processing", which under emerging Indian guidance includes **systematic processing of minors' data + automated decision-making** (your scoring algorithm makes life-affecting decisions on stream choice). The DPIA should:

1. Describe the processing.
2. Assess necessity and proportionality.
3. Identify risks to data principals.
4. Document mitigation measures.

Fix: write `docs/compliance/dpia-v1.md` . Two days of work; templates are widely available. Re-do annually.

B.8 ● P2 — Cross-Border Data Transfer

If your Supabase project is hosted outside India (default is `us-east-1` or `ap-southeast-1` — Singapore), **DPDPA Section 16** applies. The Act currently uses a "negative list" model — transfers are permitted *except* to countries on a notified blacklist. The blacklist hasn't been published yet, but:

- The deployment region of the Supabase project should be **logged in the Privacy Policy**.
 - Move to a region inside or near India (`ap-south-1` Mumbai) for both performance and regulatory clarity.
-

B.9 ● P2 — IT Rules 2021 Intermediary Compliance

Career Compass shares user-generated content via the parent share-token URL. This *technically* makes you an "intermediary" under the IT Act, requiring:

- A grievance officer (overlaps with B.5).
 - Removal of unlawful content within 36 hours of notice.
 - Monthly compliance reports if you cross the "significant social media intermediary" threshold (5M users) — not relevant near-term, but the framework is the same.
-

B.10 ● Informational — Anti-Suicide / Crisis Disclaimers

Not a DPDPA item but a **regulatory and ethical requirement**. India has seen tragic suicides linked to coaching/career pressure (Kota cluster). A career advisory app for minors must:

- Display, on every result page, the **iCALL helpline** (9152987821) and **Vandrevala Foundation** (1860-2662-345).
 - Disclaimer: *"This assessment is a guidance tool, not a substitute for professional career counselling or mental-health support."*
 - If the AI narrative ever produces concerning language (e.g. detection of distress in any open-ended input you may add later), trigger an escalation flow.
-

Section C — Remediation Plan (Prioritised)

Day 0 (do today, before any further work)

1. **Rotate the Anthropic API key**. Assume compromised.
2. **Move AI call to Supabase Edge Function** with key as a function secret.
3. **Strip all `console.log` statements** in `Results.tsx` and `AssessmentEngine.tsx` .
4. **Contact Vasanth K**, apologise, and scrub the repo.
5. **Disable counsellor signup** (front-end gate) until the RLS is rebuilt.

Week 1

6. Publish `/privacy` (privacy policy v1).
7. Add the parental-consent flow on signup (block account activation until parent OTP confirmed).
8. Add `/contact-grievance` and email forwarder.

9. Add `Content-Security-Policy` header in `netlify.toml` .
10. Add "Delete my account" to ProfileEdit.

Month 1

11. Re-implement counsellor RLS via `SECURITY DEFINER` helpers.
12. Add `share_token_expires_at` + revoke UI.
13. Add `admin_audit_log` table + triggers.
14. Run a fresh `npm audit` ; remove unused `@anthropic-ai/sdk` .
15. Enable Supabase strong-password + MFA option for staff roles.
16. Write `docs/compliance/dpia-v1.md` .
17. Define and implement data-retention policy.
18. Migrate Supabase project to `ap-south-1` if not already.

Quarter 1

19. Counsel review of privacy policy, T&Cs, parental consent text.
 20. Pen test (engage a CERT-In empanelled firm).
 21. Annual DPIA refresh.
 22. Designate Data Protection Officer (DPO) if user-count growth makes you a "Significant Data Fiduciary".
-

Section D — Verdict

The codebase has **good security primitives** (RLS, no XSS surface, server-side auth triggers, cryptographic share tokens) but is **not compliant with DPDPA 2023** on any meaningful axis. Of the ~22 distinct compliance controls that a real audit would test for, the app currently satisfies **fewer than 5**.

The 6 P0 items can be closed in **5 engineering days**. The full P1 list is **3-4 engineering weeks** plus **2 days of external legal review**. After that, Career Compass would be in a *defensible* position to onboard the first paying school — and not before.

Bottom line: *Don't open the product to paying schools or run paid acquisition until the P0 list is closed and a counsel-reviewed privacy policy is live. The cost of fixing this is days; the cost of not fixing it before a DPDPA notice is paid leadership time and reputational damage you cannot buy back.*